

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by architectural elements, including a large archway and a building with a tower. The text "CONIMBRICA" is inscribed around the bottom half of the circle, and "SITATIS" is visible at the bottom left. The seal is rendered in a light blue color.

Security Auditing

Lesson#6

NIST Cybersecurity Framework (CSF) 2.0

School Year 2025/2026

Master in Informatics Security (MSI)

Master in Informatics Engineering (MEI)

Informatics Engineering Department

University of Coimbra



Learning Objectives

- Understand the purpose and components of NIST CSF 2.0
- Learn how to apply CSF in different organizational contexts
- Discuss real-world examples and implementation challenges



Agenda

1. Overview of NIST Cybersecurity Framework (CSF) 2.0
2. NIST CSF 2.0 Core Functions
3. Implementing NIST CSF 2.0 in Organizations
4. Measuring & Improving Cybersecurity Posture
5. Summary



1. Overview of NIST CSF 2.0

What is the NIST Cybersecurity Framework (CSF)?

- Developed by the National Institute of Standards and Technology (NIST) to provide **voluntary** cybersecurity guidance.
- Originally designed for **critical infrastructure sectors** (e.g., energy, healthcare, financial services) but now adopted across industries globally.
- A **flexible framework** that organizations can tailor to their size, industry, and risk tolerance.

Why was the CSF created?

- Response to Presidential Executive Order 13636 (2013) — focused on improving cybersecurity for critical infrastructure.
- Addresses the growing number of cyber threats, data breaches, and ransomware attacks.
- Helps organizations align their cybersecurity efforts with business objectives and regulatory requirements.

NIST CSF: <https://www.nist.gov/cyberframework>



1. Overview of NIST CSF 2.0

Timeline of CSF Updates

- CSF 1.0 (2014): Initial release, focusing on risk-based cybersecurity best practices.
- CSF 1.1 (2018): Minor refinements, including supply chain risk management.
- CSF 2.0 (2024): Major update to improve usability, introduces governance, and enhance adaptability for organizations of all sizes.

Key Changes in CSF 2.0

Feature	CSF 1.1	CSF 2.0
Core Functions	5 (Identify, Protect, Detect, Respond, Recover)	6 (Govern added)
Scope	Mainly for critical infrastructure	All organizations (private, public, small businesses, government, international)
Guidance	High-level best practices	More prescriptive guidance, expanded implementation examples
Profiles	Industry-specific profiles	Customizable profiles to fit any organization
Supply Chain Risk	Introduced	Expanded with more emphasis on third-party risks



1. Overview of NIST CSF 2.0

Discussion Question:

Why do you think governance was added as a core function in CSF 2.0?



1. Overview of NIST CSF 2.0

Who Uses CSF 2.0?

Industry Adoption

- Used across various industries: banking, healthcare, government, manufacturing, retail, and small businesses.
- Adopted internationally—integrates well with ISO 27001, NIST SP 800-53, CIS Controls, and Zero Trust frameworks.

Regulatory Influence

- While voluntary, CSF is referenced in federal regulations and compliance frameworks (e.g., U.S. federal agencies, SEC cybersecurity rules, HIPAA).
- Helps organizations prove due diligence in cybersecurity risk management.

1. Overview of NIST CSF 2.0

Key Components of the CSF:

1. Framework Core:

- Six Functions: Govern, Identify, Protect, Detect, Respond, Recover.
- Categories & Subcategories: Organized best practices within each function.
- Examples of Implementation: New in CSF 2.0 to provide more practical guidance.

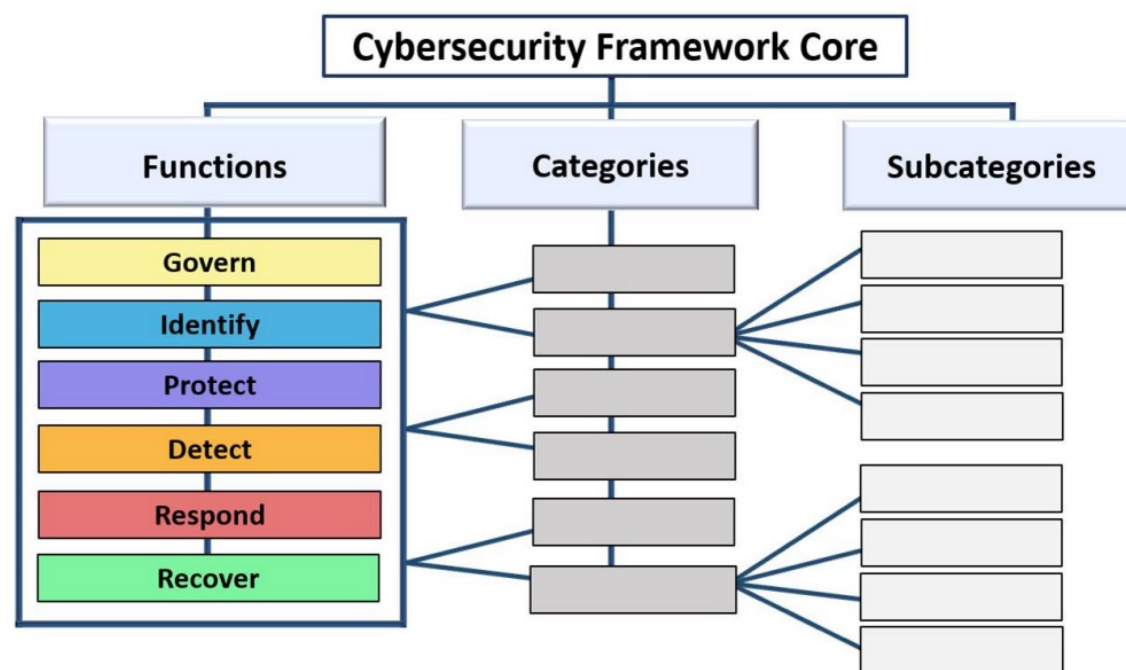


Image source: Fig. 1. CSF Core structure, The NIST Cybersecurity Framework (CSF) 2.0, <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

1. Overview of NIST CSF 2.0

Key Components of the CSF:

2. Implementation Tiers:

- Helps organizations assess their cybersecurity maturity level.
- Tiers 1-4: Partial, Risk-Informed, Repeatable, Adaptive.

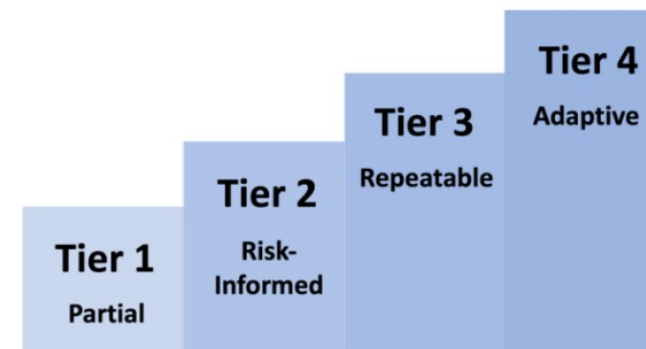


Image source: Fig. 4. CSF Tiers for cybersecurity risk governance and management, The NIST Cybersecurity Framework (CSF) 2.0, <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

1. Overview of NIST CSF 2.0

Key Components of the CSF:

3. Profiles:

- Customizable approach to align CSF with business needs and regulatory requirements.
- Can be industry-specific (e.g., financial services) or tailored to an individual company.

NIST-hosted Organizational Profiles Templates:

<https://www.nist.gov/cyberframework/profiles>

Community profiles:

<https://www.nccoe.nist.gov/applying-frameworks-resources>



Image source: Fig. 3. Steps for creating and using a CSF Organizational Profile, The NIST Cybersecurity Framework (CSF) 2.0, <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>



1. Overview of NIST CSF 2.0

Benefits of using NIST CSF 2.0

-  **Flexible & Scalable** – Adaptable for organizations of all sizes.
-  **Aligns with Global Standards** – Can be mapped to other frameworks like ISO 27001, CIS Controls, and NIST SP 800-53.
-  **Risk-Based Approach** – Focuses on prioritizing threats based on business impact.
-  **Enhances Communication** – Creates a common language between security teams and executives.
-  **Improves Cyber Resilience** – Helps organizations proactively prevent, detect, and recover from cyber incidents.



2. NIST CSF 2.0 Core Functions

Overview of the Six Core Functions

The six core functions in NIST CSF 2.0 serve as the foundation for an effective cybersecurity strategy:

Function	Purpose	Key Focus Areas
Govern	Ensures cybersecurity is embedded in leadership, strategy, and risk management.	Governance, policies, accountability, and investments.
Identify	Understands risks, assets, and vulnerabilities.	Asset management, risk assessment, supply chain security.
Protect	Implements safeguards to prevent incidents.	Access control, encryption, security training, system updates.
Detect	Identifies cybersecurity events quickly.	Threat monitoring, anomaly detection, logging.
Respond	Mitigates the impact of cyber incidents.	Incident response, communication, analysis.
Recover	Restores operations and improves defenses.	Disaster recovery, lessons learned, resilience planning.



2. NIST CSF 2.0 Core Functions

◆ 1. GOVERN (New in CSF 2.0)

📌 **Purpose:** Ensures cybersecurity is integrated into business leadership and strategy.

Function	Categories and Subcategories	Responsibilities
Govern	1. Governance, Strategy, and Oversight	Align cybersecurity with business goals
		Ensure executive leadership is accountable for cybersecurity risks
	2. Roles, Responsibilities, and Authorities	Clearly define who is responsible for cybersecurity decisions
		Assign CISO and IT security teams with clear mandates
	3. Policy, Processes, and Procedures	Develop and enforce cybersecurity policies.
		Conduct regular audits and policy reviews.



2. NIST CSF 2.0 Core Functions

◆ 1. GOVERN (New in CSF 2.0)

📌 **Purpose:** Ensures cybersecurity is integrated into business leadership and strategy.

Function	Categories and Subcategories	Responsibilities
Govern	4. Cybersecurity Supply Chain Risk Management	Assess and monitor third-party vendor security.
		Implement secure procurement policies.
	5. Investment and Resource Planning	Allocate budget and resources for cybersecurity programs.
		Ensure cybersecurity teams have the tools they need.

2. NIST CSF 2.0 Core Functions

2. IDENTIFY

 **Purpose:** Understands what needs protection and assesses risks.

Function	Categories and Subcategories	Responsibilities
Identify	1. Asset Management	Inventory all hardware, software, and data assets.
		Classify critical assets that require extra protection.
	2. Cybersecurity Risk Management	Identify threats and assess their impact.
		Use risk assessment frameworks (e.g., ISO 27005, FAIR Model).
	3. Business Environment	Understand how cybersecurity risks impact business operations.
		Define mission-critical systems and processes.
	4. Supply Chain Risk Management	Assess risks from third-party vendors and cloud providers.
		Ensure compliance with cybersecurity best practices.

2. NIST CSF 2.0 Core Functions

◆ 3. PROTECT

📌 **Purpose:** Implements safeguards to minimize cyber risks.

Function	Categories and Subcategories	Responsibilities
Protect	1. Identity Management, Authentication, and Access Control	Implement multi-factor authentication (MFA).
		Enforce role-based access control (RBAC).
	2. Awareness and Training	Educate employees on phishing attacks and password hygiene.
		Conduct regular security awareness training.
	3. Data Security	Encrypt sensitive data at rest and in transit.
		Implement data loss prevention (DLP) solutions.
	4. Technology Infrastructure Resilience	Patch and update software and firmware regularly.
		Configure firewalls, antivirus, and endpoint security.



2. NIST CSF 2.0 Core Functions

◆ 4. DETECT

📌 **Purpose:** Identifies cybersecurity incidents quickly.

Function	Categories and Subcategories	Responsibilities
Detect	1. Threat Detection and Monitoring	Deploy intrusion detection systems (IDS) and SIEM tools.
		Monitor network traffic for anomalies.
	2. Anomalies and Security Events	Use AI-driven analytics to detect unusual behavior.
		Investigate failed login attempts, data transfers, and insider threats.
	3. Logging and Event Analysis	Maintain detailed logs of security events.
		Correlate log data to identify attack patterns.



2. NIST CSF 2.0 Core Functions

◆ 5. RESPOND

📌 **Purpose:** Mitigates cyber incidents to reduce damage.

Function	Categories and Subcategories	Responsibilities
Respond	1. Incident Response Plan Execution	Define clear steps for responding to attacks.
		Assign roles and responsibilities for response teams.
	2. Analysis and Forensics	Investigate how an attack occurred.
		Use digital forensics to trace attackers.
	3. Communications and Notifications	Notify affected customers and regulators.
		Follow data breach reporting laws (e.g., GDPR, CCPA).



2. NIST CSF 2.0 Core Functions

◆ 6. RECOVER

📌 **Purpose:** Restores operations after a cyber incident.

Function	Categories and Subcategories	Responsibilities
Recover	1. Recovery Planning	Implement disaster recovery (DR) strategies.
		Ensure backups are tested regularly.
	2. Improvements and Lessons Learned	Conduct post-incident reviews.
		Update security policies to prevent future attacks.
	3. Communication and Stakeholder Engagement	Inform customers, regulators, and partners of recovery efforts.
		Maintain trust and transparency.



3. Implementing NIST CSF 2.0 in Organizations

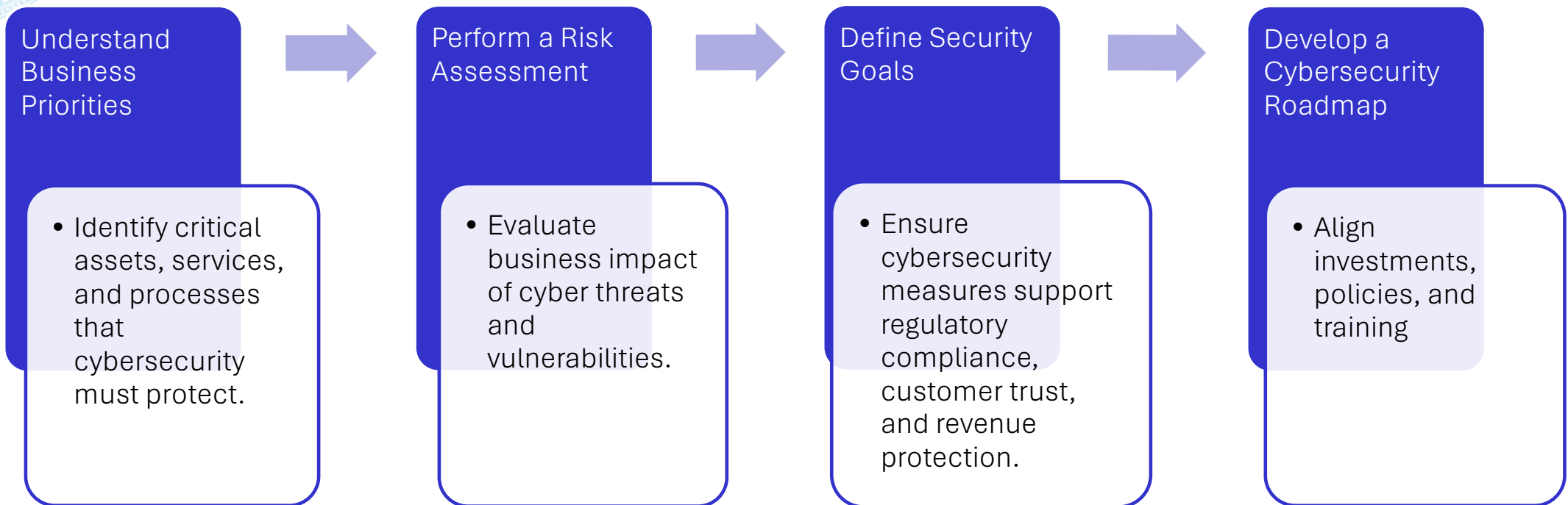
Aligning CSF with Business Objectives

◆ Why Align Cybersecurity with Business Goals?

- Cybersecurity is not just an IT issue; it is a **business risk**.
- NIST CSF 2.0 ensures that **cybersecurity strategies support** business continuity, reputation, and compliance.
- Organizations must **balance security, cost, and operational efficiency**.

3. Implementing NIST CSF 2.0 in Organizations

Key Steps to Align CSF with Business Objectives





3. Implementing NIST CSF 2.0 in Organizations

Challenges in Implementing CSF 2.0

◆ Common Barriers to Implementation

- ✗ **Lack of Executive Buy-In:** Leadership may not see cybersecurity as a business priority.
- ✗ **Resource Constraints:** Small and medium businesses may lack funding and expertise.
- ✗ **Complex IT Environments:** Legacy systems may not easily integrate with modern security controls.
- ✗ **Regulatory Overlap:** Organizations must comply with multiple frameworks and regulations (e.g., GDPR, HIPAA).
- ✗ **Employee Resistance:** Cybersecurity policies may introduce friction in daily workflows.



3. Implementing NIST CSF 2.0 in Organizations

Challenges in Implementing CSF 2.0

◆ Strategies to Overcome Challenges

- ✓ **Communicate Cybersecurity ROI:** Show how security investments prevent financial losses.
- ✓ **Prioritize Risk-Based Approach:** Focus on high-impact threats first.
- ✓ **Automate Security Processes:** Use AI-driven monitoring tools to reduce manual effort.
- ✓ **Foster a Cybersecurity Culture:** Train employees on security best practices.



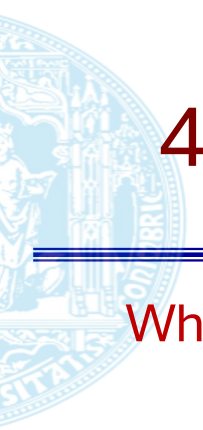
3. Implementing NIST CSF 2.0 in Organizations

How CSF 2.0 Works with Other Frameworks

Organizations often follow multiple cybersecurity frameworks. CSF 2.0 acts as a bridge between different standards:

Framework	Purpose	How It Integrates with CSF 2.0
ISO 27001	Information security management system (ISMS)	CSF provides a risk-based approach that complements ISO's security controls.
CIS Controls	Specific security controls for threat mitigation	CSF maps directly to CIS Controls for tactical implementation.
NIST 800-53	Federal security controls framework	CSF aligns with risk management and compliance for government organizations.
Zero Trust	Identity and access-focused security model	CSF helps organizations plan and implement Zero Trust strategies.

 Discussion Question: Which framework do you think is most critical for highly regulated industries like healthcare and finance? Why?



4. Measuring & Improving Cybersecurity Posture

What is CSF Maturity?

- Maturity refers to **how well** an organization implements and maintains cybersecurity practices.
- NIST CSF 2.0 **does not define maturity levels explicitly**, but organizations often use models like:
 - CMMI (Capability Maturity Model Integration)
 - C2M2 (Cybersecurity Capability Maturity Model)

Maturity Assessment Process

- ✓ **Step 1:** Identify Current State → Evaluate security controls using CSF functions, categories, and subcategories.
- ✓ **Step 2:** Define Target State → Set goals for cybersecurity maturity based on risk tolerance.
- ✓ **Step 3:** Conduct a Gap Analysis → Identify areas where the organization falls short.
- ✓ **Step 4:** Prioritize Improvements → Focus on high-impact risks first.



4. Measuring & Improving Cybersecurity Posture

Key Metrics for Cybersecurity Performance

Why Metrics Matter?

- Help measure the **effectiveness** of cybersecurity investments.
- Provide **insights** for executive decision-making.
- **Support** continuous improvement.

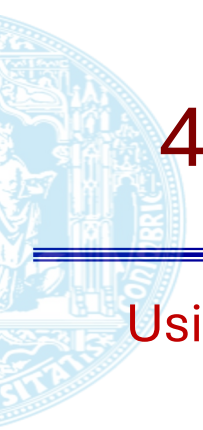
4. Measuring & Improving Cybersecurity Posture

Key Metrics for Cybersecurity Performance

Examples of security metrics

Metric	Description	Relevance to CSF
Mean Time to Detect (MTTD)	Average time to identify a security incident	Measures effectiveness of Detect function
Mean Time to Respond (MTTR)	Time taken to contain and remediate an attack	Evaluates Response function
Patch Management Time	Time taken to apply security updates	Related to Protect function
Phishing Click Rate	Percentage of employees who fall for phishing attacks	Measures effectiveness of Awareness Training in Govern function
Compliance Score	Percentage of security controls meeting regulatory requirements	Assesses overall cybersecurity posture

 **Discussion Question: Which metric do you think is most important for an organization's cybersecurity? Why?**

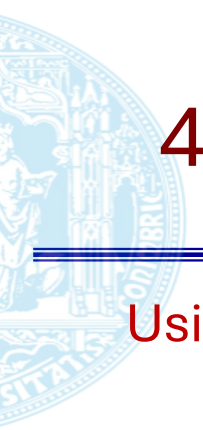


4. Measuring & Improving Cybersecurity Posture

Using CSF Profiles for Continuous Improvement

What Are CSF Profiles?

- CSF Profiles help tailor the framework to an organization's specific risks, needs, and regulatory environment.
- Organizations can create:
 - Current Profile → Where they stand today.
 - Target Profile → Where they want to be.
 - Action Plan → Steps to bridge the gap.

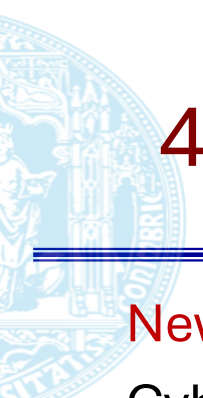


4. Measuring & Improving Cybersecurity Posture

Using CSF Profiles for Continuous Improvement

Examples of CSF profiles

Organization	Current Profile	Target Profile	Key Actions
Small Business	Basic cybersecurity practices	Enhanced protections for customer data	Implement MFA, employee training, automated backups
Bank	Advanced security, but legacy systems	Full Zero Trust implementation	AI-driven monitoring, biometric authentication



4. Measuring & Improving Cybersecurity Posture

New & Evolving Cyber Threats

Cybersecurity is dynamic—organizations must adapt their CSF implementation to address emerging risks:

Threat	Challenge	CSF Adaptation
AI-Based Attacks	Hackers use AI for automated phishing and deepfake scams	Improve Detect function with AI-powered threat intelligence
Cloud Security Risks	Misconfigurations expose sensitive data	Strengthen Govern and Protect functions for cloud compliance
Ransomware Evolution	Attackers use double extortion techniques	Enhance Recover function with robust backups and incident response
Supply Chain Attacks	Vulnerabilities in third-party vendors	Expand Identify function to assess third-party risks



5. Summary & Key Takeaways

① Overview of NIST CSF 2.0

- ✓ CSF 2.0 provides a flexible, risk-based approach to cybersecurity.
- ✓ Six Core Functions: Govern, Identify, Protect, Detect, Respond, Recover.
- ✓ Helps organizations manage cyber risks and improve resilience.

② Deep Dive into the Six Core Functions

- ✓ Each function has categories & subcategories covering policies, asset management, threat detection, incident response, and recovery.
- ✓ Supports a structured yet adaptable approach to cybersecurity.



5. Summary & Key Takeaways

③ Implementing CSF 2.0 in Organizations

- ✓ CSF aligns cybersecurity with business objectives to minimize risk.
- ✓ Challenges include executive buy-in, resource constraints, and compliance complexity.
- ✓ Integrates with ISO 27001, CIS Controls, NIST 800-53, and Zero Trust.
- ✓ Case studies (Finance & Healthcare) highlight real-world applications.

④ Measuring & Improving Cybersecurity Posture

- ✓ CSF maturity assessment helps track progress and prioritize improvements.
- ✓ Key metrics (MTTD, MTTR, compliance score) measure cybersecurity performance.
- ✓ CSF Profiles help organizations customize and continuously improve security.
- ✓ CSF must adapt to AI-based threats, cloud security risks, and ransomware attacks.